

---

## ENGENHARIA DE COMPUTAÇÃO

Disciplina: Engenharia de Software

### KA 13 — Segurança de Software

(Software Security)

#### Documento de Análise de Segurança, OWASP e Conformidade LGPD

|                          |                                                                                                                                                                          |
|--------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Instituição de Ensino    | UNOESC                                                                                                                                                                   |
| Professor(a) Responsável | Odemir Moreira da Mata Jr.                                                                                                                                               |
| Disciplina               | Engenharia de Software                                                                                                                                                   |
| Turma / Semestre         | JBA620-6                                                                                                                                                                 |
| Integrantes do Grupo     | Ana Clara Viganó Prestes de Oliveira, Davi Antônio Basotto Minati, Elian Baldasso Pereira Duarte, Jasmine Masson Alves, Lucas Eduardo Heydt, Vitória Aparecida Vendausen |
| Data de Entrega          | 24/06/2026                                                                                                                                                               |

---

## Histórico de Versões

| Versão | Data       | Autor(es)    | Descrição                              | Revisado por      |
|--------|------------|--------------|----------------------------------------|-------------------|
| v1.0   | 24/04/2026 | Ana Clara    | Modelagem inicial de ameaças STRIDE.   | Jasmine Alves     |
| v1.1   | 08/05/2026 | Elian Duarte | Inclusão dos controles OWASP e LGPD.   | Davi Minati       |
| v1.2   | 22/05/2026 | Ana Clara    | Revisão dos controles técnicos e RIPD. | Vitória Vendausen |

## 1. Introdução

### 1.1 Escopo da Análise de Segurança

Este documento estabelece as diretrizes arquiteturais e operacionais de proteção de dados para o sistema de gestão clínica. O escopo abrange a identificação de ameaças aos microsserviços, modelagem de segurança nas camadas de rede, aplicação e banco de dados, e a mitigação de vulnerabilidades sistêmicas. O foco principal é a proteção de Prontuários Eletrônicos de Pacientes (PEP), garantindo os princípios de Confidencialidade, Integridade e Disponibilidade (Tríade CIA).

### 1.2 Referências — OWASP Top 10, STRIDE, LGPD

A estratégia de segurança baseia-se em três pilares metodológicos:

- OWASP Top 10 (2021): Padrão da indústria para mitigação das vulnerabilidades mais críticas em aplicações web.
- Microsoft STRIDE: Framework de modelagem de ameaças focado na decomposição de componentes e fluxos de dados.
- LGPD (Lei nº 13.709/2018): Base legal brasileira, com foco rigoroso no Artigo 5º (Dados Sensíveis), Artigo 11º (Tratamento de Dados de Saúde) e Artigo 46º (Medidas de Segurança Técnicas).

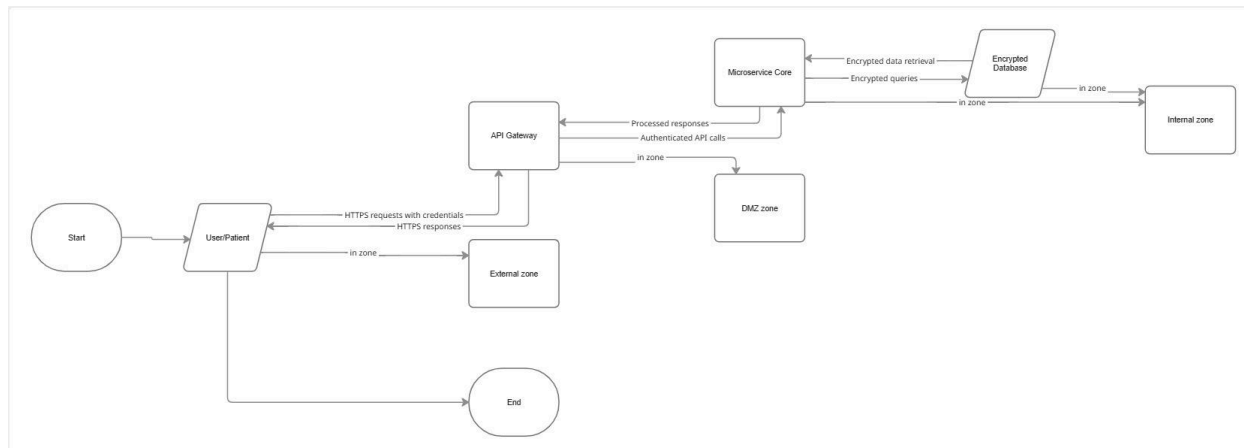
## 2. Análise de Ameaças — Metodologia STRIDE

### 2.1 Aplicação do STRIDE ao Sistema de Consultório

A metodologia STRIDE foi aplicada durante a fase de design (Shift-Left Security) para mapear vetores de ataque nas interfaces do sistema. A análise categoriza as ameaças em: **Spoofing** (Falsificação de Identidade), **Tampering** (Adulteração de Dados), **Repudiation** (Repúdio), **Information Disclosure** (Divulgação de Informações), **Denial of Service** (Negação de Serviço) e **Elevation of Privilege** (Elevação de Privilégio). Cada rota da API e tabela de banco

de dados foi avaliada contra essas seis categorias para gerar os controles de mitigação presentes no catálogo.

## 2.2 Diagrama de Fluxo de Dados (DFD) para Threat Modeling (inserir)



## 2.3 Catálogo de Ameaças Identificadas

As ameaças descobertas na modelagem do DFD foram documentadas e classificadas de acordo com o risco (Alto, Médio, Baixo), servindo como base para a criação de tarefas no backlog de segurança (DevSecOps). O catálogo detalhado encontra-se na seção de Tabelas deste documento

## 3. Checklist OWASP Top 10

O sistema adota arquitetura de defesa em profundidade para mitigar as categorias de risco web. A manifestação prática dessas falhas no contexto clínico e seus controles exatos foram planejados na Tabela OWASP consolidada no fim deste artefato, guiando as revisões de código (*Code Review*) da equipe.

## 4. Conformidade LGPD no Design de Segurança

### 4.1 Mapeamento de Dados Pessoais e Sensíveis Tratados

O sistema classifica os ativos de informação em dois grupos principais: dados pessoais comuns e dados pessoais sensíveis.

Os dados pessoais comuns incluem informações como nome completo, CPF, RG, data de nascimento, endereço, telefone e e-mail. Esses dados são utilizados para identificação e cadastro dos pacientes, sendo acessados pela recepção e pela equipe clínica conforme suas atribuições.

Já os dados pessoais sensíveis, conforme definido no Art. 5º, inciso II, da LGPD, abrangem informações relacionadas ao histórico familiar, diagnósticos médicos, evolução clínica, prescrições de medicamentos controlados e laudos de exames. Devido ao seu caráter sensível, o acesso a esses dados é restrito aos profissionais diretamente envolvidos no atendimento do paciente.

### 4.2 Controles Técnicos Obrigatórios

Criptografia em trânsito (TLS): Configuração obrigatória de TLS 1.3 no API Gateway e balanceadores de carga, com desativação de cifras fracas e suporte a HSTS (HTTP Strict Transport Security).

Criptografia em repouso (AES-256 ou equivalente): Discos virtuais (EBS) e instâncias de banco de dados nativamente encriptados utilizando o algoritmo AES-256 via serviço de gerenciamento de chaves na nuvem (KMS).

Controle de acesso baseado em papel (RBAC): Implementação do modelo de Menor Privilégio. Perfis operacionais (recepcao) só possuem métodos GET e POST para tabelas de agendamento. Apenas perfis clínicos (medico) possuem escopo para interagir com o endpoint /prontuarios.

Log de auditoria (imutável): Toda inserção, alteração ou leitura de prontuário gera um evento do tipo "Write-Once-Read-Many" (WORM). O log captura carimbo de tempo, IP e ID do usuário, não podendo ser editado nem por administradores do banco de dados (DBA).

Anonimização / pseudonimização: Técnicas de hash unidirecional (Bcrypt) para senhas e mascaramento visual de dados em tela de recepção (ex: exibindo apenas os 4 últimos dígitos do CPF).

4.3 Direitos dos Titulares de Dados (Art. 18 LGPD)

4.4 Relatório de Impacto à Proteção de Dados (RIPD) — simplificado

Tabelas e Formulários

Catálogo de Ameaças STRIDE

| ID    | Categoria STRIDE | Ameaça Identificada                                             | Componente Afetado  | Risco (A/M/B) | Controle de Mitigação                                                              |
|-------|------------------|-----------------------------------------------------------------|---------------------|---------------|------------------------------------------------------------------------------------|
| AM-01 | Spoofing         | Atacante rouba credenciais de um médico para acessar o sistema. | API de Autenticação | A             | Implantação de Multi-Factor Authentication (MFA) obrigatória para perfis clínicos. |
| AM-02 | Spoofing         | Dispositivo não autorizado forja conexão com a API de Back-end. | API Gateway         | M             | Exigência de tokens JWT assinados com tempo de expiração curto (15 min).           |
| AM-03 | Tampering        | Interceptação e alteração de um formulário de prescrição em     | Camada de Rede      | A             | Enforcing de HTTPS (TLS 1.3) em todas as rotas;                                    |

|       |                        |                                                                                         |                          |   |                                                                                                                       |
|-------|------------------------|-----------------------------------------------------------------------------------------|--------------------------|---|-----------------------------------------------------------------------------------------------------------------------|
|       |                        | trânsito.                                                                               |                          |   | verificação de integridade do payload.                                                                                |
| AM-04 | Tampering              | Modificação direta de dados médicos no banco por um administrador corrompido.           | Banco de Dados           | A | Criptografia a nível de coluna (Transparent Data Encryption) e restrição de permissão de UPDATE sem log.              |
| AM-05 | Repudiation            | Médico prescreve medicamento errado e nega a autoria no sistema.                        | Microsserviço Prontuário | A | Implementação de logs de auditoria imutáveis com assinatura atrelada ao usuário.                                      |
| AM-06 | Information Disclosure | Vazamento de backup do banco de dados contendo dados sensíveis de pacientes.            | Storage/Backup           | A | Criptografia em repouso (AES-256) em todos os volumes de armazenamento de backup.                                     |
| AM-07 | Information Disclosure | Falha exibe stack trace do servidor com chaves de acesso em ambiente produtivo.         | Tratamento de Erros      | M | Padronização global de tratamento de exceções para retornar apenas mensagens genéricas ao cliente.                    |
| AM-08 | Denial of Service      | Botnet inunda o endpoint de agendamentos impedindo marcações legítimas.                 | Balanceador de Carga     | M | Configuração de Rate Limiting (ex: max 20 req/min por IP) e Web Application Firewall (WAF).                           |
| AM-09 | Elevation of Privilege | Recepcionista adultera o payload JSON para alterar seu papel (role) para administrador. | Autorização (JWT)        | A | Validação severa de assinatura JWT no back-end. Papéis extraídos exclusivamente da claim não manipulável do servidor. |

|       |                        |                                                                                               |                   |   |                                                                                                                |
|-------|------------------------|-----------------------------------------------------------------------------------------------|-------------------|---|----------------------------------------------------------------------------------------------------------------|
| AM-10 | Elevation of Privilege | Exploração de Insecure Direct Object Reference (IDOR) para ver prontuário de paciente alheio. | Controller de API | A | Checagem de propriedade de dados no servidor antes de devolver a query (validação de patient_id vs doctor_id). |
|-------|------------------------|-----------------------------------------------------------------------------------------------|-------------------|---|----------------------------------------------------------------------------------------------------------------|

## | Checklist OWASP Top 10

| #   | Vulnerabilidade OWASP     | Manifestação no Sistema                                                | Controle de Design Proposto                                                           | Risco Residual |
|-----|---------------------------|------------------------------------------------------------------------|---------------------------------------------------------------------------------------|----------------|
| A01 | Broken Access Control     | Recepcionista acessando URL /api/prontuario/123 diretamente.           | Implementação de middleware RBAC e checagem anti-IDOR por recurso.                    | Baixo          |
| A02 | Cryptographic Failures    | Dados de saúde furtados em texto claro (Plaintext) do servidor.        | TLS 1.3 (Trânsito) e AES-256 (Repouso). Proibição de algoritmos obsoletos (MD5/SHA1). | Baixo          |
| A03 | Injection                 | Atacante enviando query SQL maliciosa no campo "Nome do Paciente".     | Utilização exclusiva de ORM (Object-Relational Mapping) ou Prepared Statements.       | Baixo          |
| A04 | Insecure Design           | Fluxo de recuperação de senha que permite adivinhar contas existentes. | Mensagens de erro genéricas e limite de taxa em formulários sensíveis.                | Baixo          |
| A05 | Security Misconfiguration | Servidor rodando com permissões root e diretórios desprotegidos.       | Contêineres operando em modo non-root e Hardening do ambiente de nuvem.               | Baixo          |
| A06 | Vulnerable Components     | Uso de biblioteca PDF geradora de laudos com falha CVE conhecida.      | Varredura de Software Composition Analysis (SCA) contínua no pipeline CI/CD.          | Baixo          |
| A07 | Auth & Session            | Sequestro de                                                           | Expiração de                                                                          | Baixo          |

|     |                               |                                                                  |                                                                                         |       |
|-----|-------------------------------|------------------------------------------------------------------|-----------------------------------------------------------------------------------------|-------|
|     | Failures                      | sessão após médico esquecer o sistema logado.                    | sessão por inatividade e armazenamento de tokens em cookies HttpOnly.                   |       |
| A08 | Software Integrity Failures   | Pipeline de CI/CD puxando imagem maliciosa para deploy.          | Assinatura digital de imagens Docker e pull apenas de repositórios privados (ECR).      | Baixo |
| A09 | Logging & Monitoring Failures | Invasão não detectada por dias devido à falta de alertas.        | Alertas automatizados para anomalias (ex: múltiplos logins falhos) via PagerDuty/Slack. | Médio |
| A10 | Server-Side Request Forgery   | Atacante forçando o servidor a buscar arquivos internos na rede. | Validação estrita (Allowlist) de URLs inseridas por usuários e isolamento de rede VPC.  | Baixo |

## | Mapeamento de Dados Pessoais — LGPD

| Dado                        | Classificação (Comum/Sensível) | Onde Armazenado                       | Quem Acessa       | Base Legal (Art. LGPD) | Controle Aplicado                                   |
|-----------------------------|--------------------------------|---------------------------------------|-------------------|------------------------|-----------------------------------------------------|
| CPF do paciente             | Comum                          | Banco Relacional (Tabela pacientes)   | Recepção e Médico | Art. 7º                | Máscara de UI em telas de recepção.                 |
| Diagnóstico médico          | Sensível (Art. 5º, II)         | Banco Relacional (Tabela prontuarios) | Exclusivo Médico  | Art. 11º               | Criptografia e RBAC rígido.                         |
| Histórico de medicamentos   | Sensível (Art. 5º, II)         | Banco Relacional (Tabela prescricoes) | Exclusivo Médico  | Art. 11º               | Criptografia e Registro WORM (Append-Only).         |
| Resultados de exames        | Sensível (Art. 5º, II)         | Object Storage (S3 / Blob)            | Exclusivo Médico  | Art. 11º               | Armazenamento privado sem acesso público e AES-256. |
| Log de acesso ao prontuário | — (Sistema)                    | Banco de Auditoria (NoSQL/Log)        | DPO / Auditoria   | Art. 46                | Logs imutáveis para garantir rastreabilidade.       |

## | Observações e Referências Consultadas

**OWASP (Open Worldwide Application Security Project):** OWASP Top 10:2021. Consulta aos vetores de ameaça A01 a A10 para implementação de defesas ativas na arquitetura web.

**Lei Geral de Proteção de Dados Pessoais (LGPD):** Lei nº 13.709/2018, Brasil. Foco analítico nos direitos dos titulares (Art. 18) e nos requisitos excepcionais para tratamento de dados sensíveis de tutela da saúde (Art. 11, II).

**SWEBOK v4.0 (Guide to the Software Engineering Body of Knowledge):** IEEE Computer Society. Consulta focada no *Chapter 14: Software Security*, aplicando princípios de design seguro, modelagem de ameaças e mitigação de vulnerabilidades sistêmicas.

**Microsoft Threat Modeling:** Metodologia STRIDE adotada para decomposição e identificação de anomalias estruturais nos processos de autenticação e rede.

**ISO/IEC 27001 e 27701:** Referências fundamentais sobre Sistemas de Gestão da Segurança da Informação e extensão para privacidade da informação.